



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

智能设备安全漏洞研究和防护

Smart vs. Security: IoT Security and Protections

Yier Jin (金意儿)

Department of Electrical Engineering and Computer Science (电子工程与计算机系)

University of Central Florida (中佛罗里达大学)

Security in Silicon Lab (SSL)

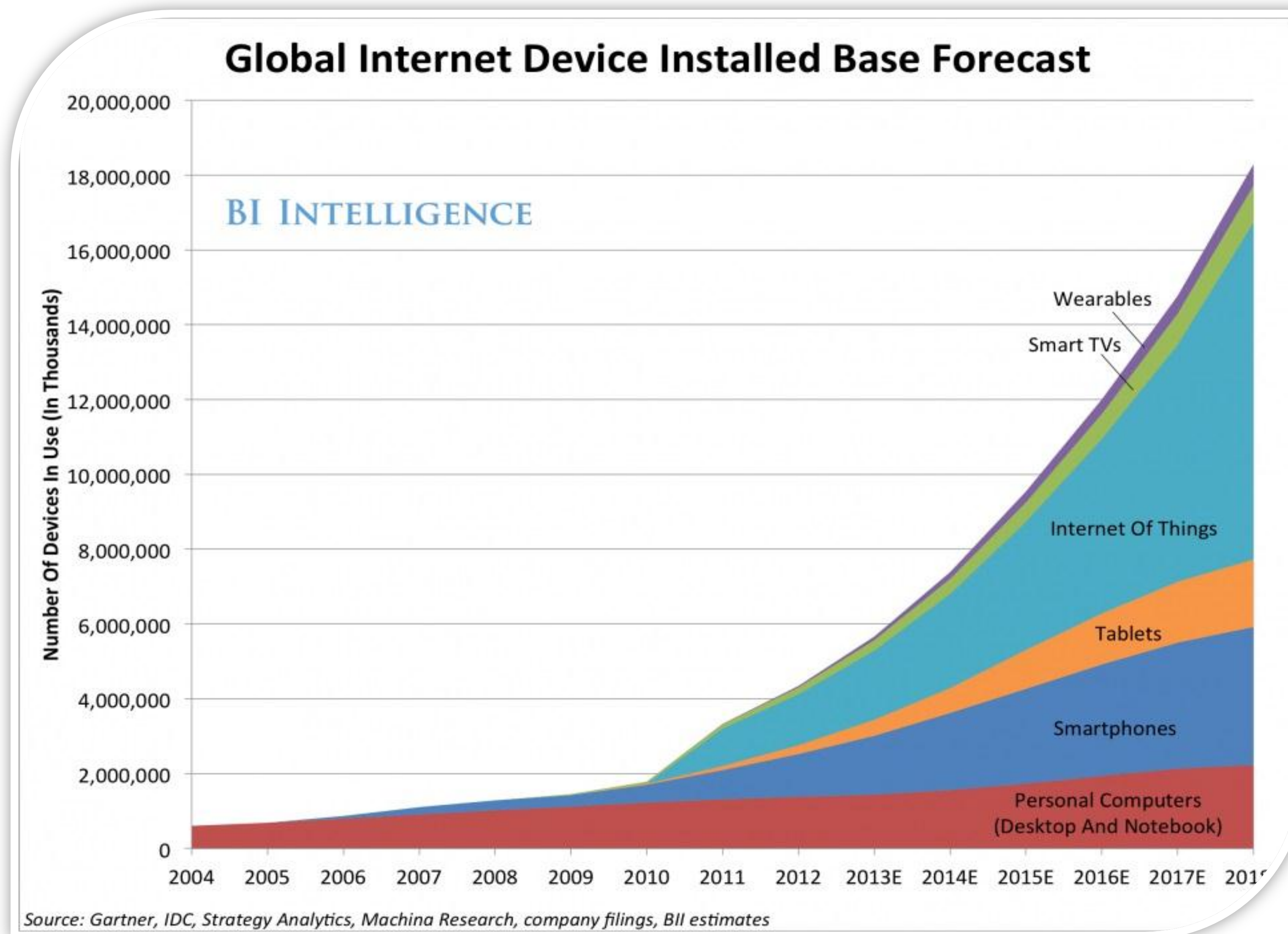
yier.jin@eecs.ucf.edu



物联网和可穿戴设备



Assorted images found online.





- 能否也能考虑“安全”？

无线连接

远程控制

随时
接入

机器学习

大数据

云计算

安全



- 安全考量
 - “ThingBot”：至少75万封钓鱼和垃圾邮件从被感染的智能电视、智能冰箱上被发送
 - WeMo “Light Switch（智能开关）”固件可以被远程控制
- 隐私考虑

个人信自左田白不知挂挂口下被十具收佳

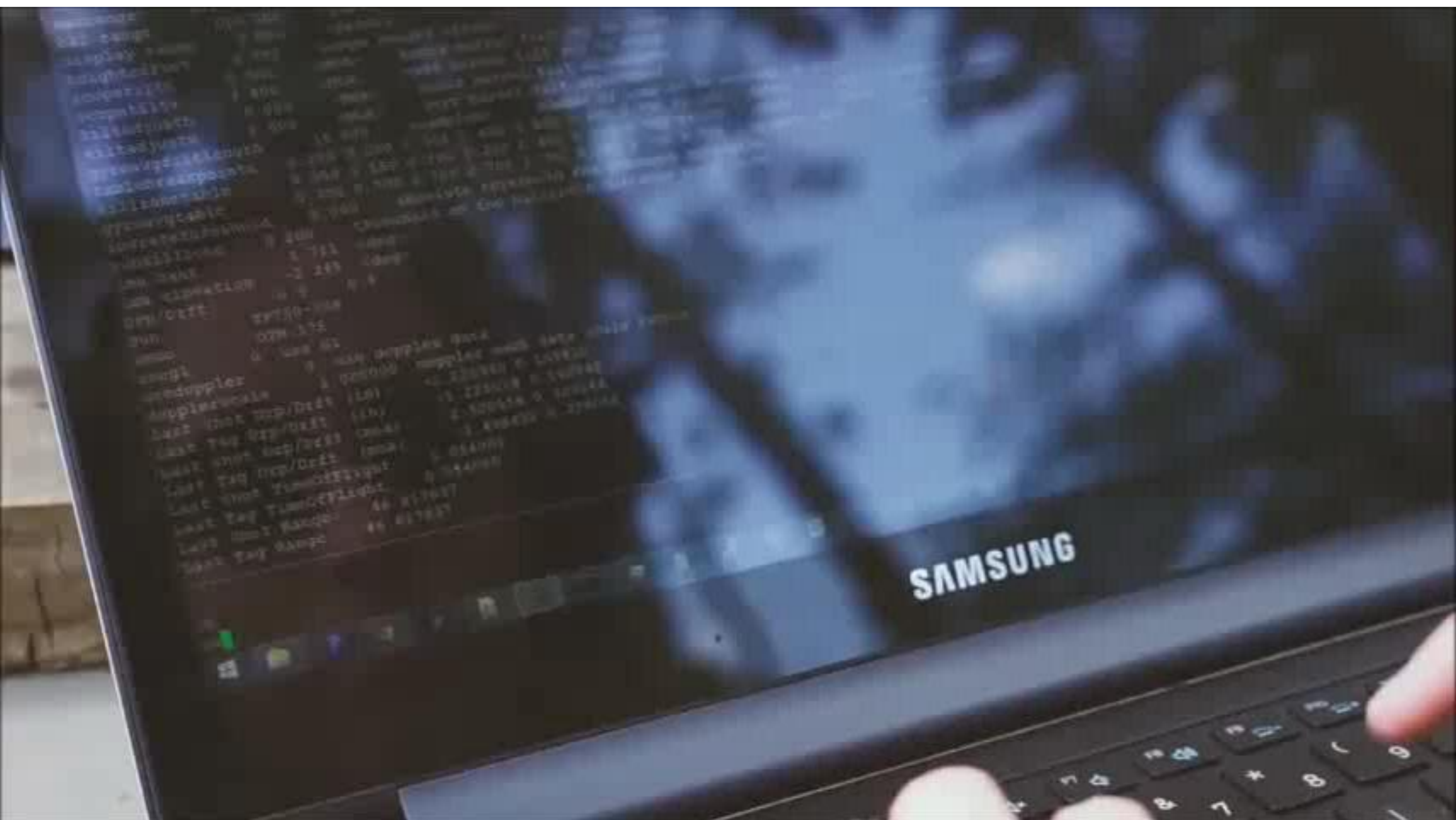
因为对特定智能设备的攻击，使得工业级的危害成为可能时，我们是否还对物联网设备的各种安全隐患无动于衷呢？

现有的智能设备到底有多（不）安全？

CNN Exclusive
DHS Video

CNN





现有的智能设备到底有多（不）安全？

Google Nest 智能温控器

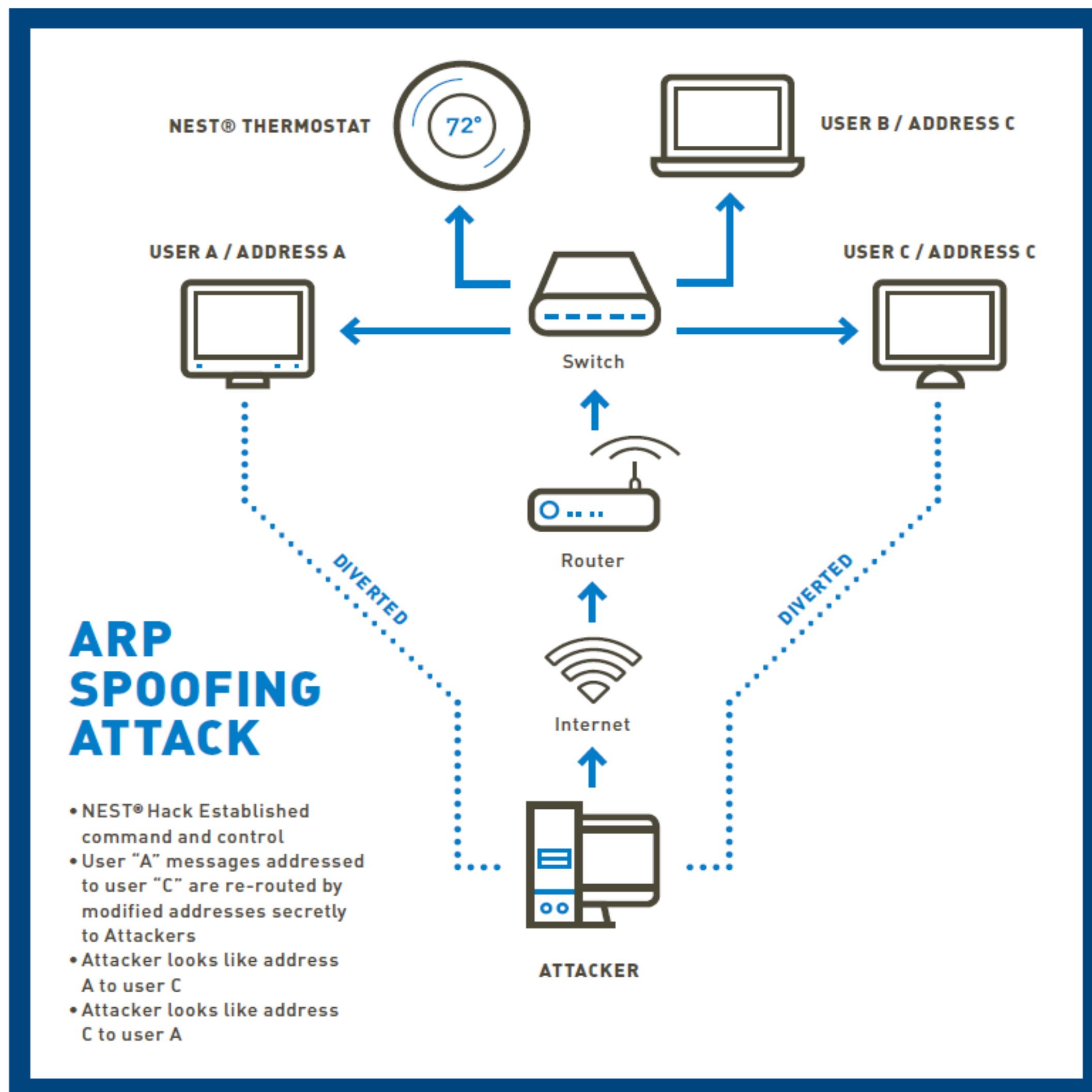
- 功能
 - 智能温控
- 设备漏洞
 - 跳过固件检测直接安装任意用户文件系统
- 危害
 - 设备远程控制及隐私获取





- ARP监听

- 控制Nest
- 从其他联网设备中收集用户数据
- 监听整个局域网
- 攻击局域网中其他电脑和设备



- 功能
 - 智能烟雾报警器
 - 智能家居中的重要一环
- 设备漏洞
 - 用户可以直接修改固件
- 危害
 - 人身伤害
 - 用户体验

- 功能
 - 健康检测
 - 无线芯片
 - ARM核
 - USB充电
 - LED显示
 - 蓝牙4.0和智能手机连接
- 设备漏洞
 - 绕过固件完整性监测
 - 启动任意固件
- 危害
 - 用户隐私泄露

- 功能
 - 流媒体电视
- 设备漏洞
 - 启动过程中包含Telnet后门
 - 加载用户U-Boot
- 危害
 - 用户可以获取root账号来执行任意命令



- 功能
 - 远程控制开关
- 设备漏洞
 - 用户可以进入Root界面
- 危害
 - 连接到Wemo上的电子设备可以被远程开和关
 - 物理破坏



Epson Artisan 700/800

- 功能
 - 集成功能打印机
 - 无线连接
- 设备漏洞
 - 通过串口可获取root界面
 - 用户可以接触到设备控制菜单
- 危害
 - 信息泄露



Amazon Fire TV Stick

- 功能
 - 流媒体电视
 - 包含HDMI接口
- 设备漏洞
 - 用户可以获取root权限
- 危害
 - 用户可以任意修改设备控制



Amazon Fire TV Box

- 功能
 - 机顶盒
 - 包含HDMI接口
- 设备漏洞
 - 拷贝SuperSU APK
 - 拷贝“su”命令到“bin”目录
 - 获取root权限
- 危害
 - Amazon已经修复该问题，任何尝试获取root权限的行为会使设备无法使用
 - 未修复设备，用户依旧可以获得root权限



- 功能

- 用户用电量收集
- 无线传输到收集端



- 缺乏有效保护
 - 大量的物联网设备
 - 设计周期短
 - 缺乏有效的安全规范和准则
- 解决方案
 - 理解物联网的安全隐患
 - 定义“设计准则”来消除、减弱这些安全隐患
- 标准测试工具
 - 自动生成测试向量
 - 系统化分析和检测设备安全
 - 自动生成设备安全检测报告

- 安全隐患详细描述
- 攻击者
- 攻击方式
- 安全漏洞
- 攻击带来的技术上的影响
- 攻击带来的商业上的影响
- 漏洞列举
- 攻击案例
- 消除攻击指南
- “为了安全而设计” （而不是 “为了设计而安全” ）

安全设计准则 – 物联网篇



中国互联网安全大会



360互联网安全中心



- 对各类漏洞设计相应规范和准则
- 发现新的漏洞
- 自动化检测工具的设计
- 低成本技术的研发来消除各类攻击

目标：自动化的物联网设备安全检测框架和工具链，快速检测任意物联网设备，同时自动生成有针对性的低成本解决方案，最终帮助实现“为了安全而设计”。



谢谢！

Yier Jin (金意儿)

University of Central Florida (中佛罗里达大学)

Email: yier.jin@eecs.ucf.edu